

API Authentication

Tokens, OAuth 2.0, JWT and access control for APIs.

Authentication vs authorization

Authentication proves identity; authorization determines what that identity may access.

OAuth 2.0 and tokens

Access tokens are common in modern APIs. QA should validate missing, invalid and expired tokens, incorrect scopes and refresh flows where applicable.

JWT

JWT is a token format. Validate signature, expiration, claims and API behavior; decoding the payload alone does not prove validity.

QA Tip

Include negative authentication tests for every protected API.

Official: <https://datatracker.ietf.org/doc/html/rfc6749>